SUNHAVEN CARE / RELEASE 9.0

Final product report

Features, implementation, security, verification and deployment boundaries

Prepared 25 September 2026. Controlled synthetic-data demonstration release.

Evidence boundary: local functionality has been tested. Live tenant integration, external security assessment and browser-based visual validation are not completed.

Illustrations in this document are labelled static HTML renderings of actual tested HTTP responses. They are not browser screenshots; JavaScript was not executed by the renderer.

Contents

1. Executive summary and Sunhaven outcomes
2. Baseline comparison and final feature inventory
3. Implemented care workflows and illustrated evidence
4. Security, automation and intelligent assistance
5. Architecture, database and integration design
6. Testing results and second audit
7. Run instructions and presentation flow
8. Production prerequisites, limitations and future customisation
9. References and evidence index

1. Executive summary

Sunhaven is a workforce-access governance application for a care organisation where employees, casual staff, agency workers and contractors frequently join, move between sites and leave. It gives managers a record of who should have access, gives operators controlled ways to change that access, and records evidence of decisions.

This final iteration extends the existing version 8 project rather than replacing it. The original uploaded project is preserved in original/: all 545 manifest-tracked files still match their SHA-256 hashes. The expanded portal is a separate local Python application with integration adapters to the original threat and agency modules.

Release result	Verified outcome
Automated suites	88 portal tests + 66 SITAS tests + 13 SAIF tests = 167 passing tests.
Acceptance run	15 scenario groups; 103 real HTTP requests on the stdlib server and the same 103 on Waitress.
Data checks	40 application tables; database integrity ok; zero foreign-key errors; backup/restore rehearsal passed.
Demonstration seed	42 workers, 30 fictional residents, 35 notes, 46 qualification records, 3 sites and 3 teams.
Release classification	Tested local enterprise-style prototype. Not certified for production healthcare use.
Visual limitation	Remote browser cannot open localhost. Report figures are explicitly labelled static HTML renderings.

A feature-rich prototype and a production-certified deployment are different milestones. This release implements local control behavior, but real Entra/MFA operation, cloud provisioning, external delivery, performance at enterprise scale and independent security assessment still require organisation-specific infrastructure and validation.

How this helps Sunhaven

Care-workforce problem	Implemented response
High turnover leaves stale accounts	Leaver revocation, reviewed roster changes and daily expired-agency deprovisioning.
Cover staff need short-lived access	Two-stage, time-limited site coverage with current role and qualification checks.
A nurse needs urgent resident access	Narrow break-glass grant with reason, expiry, manager alert and independent closure.
Qualifications expire unnoticed	Qualification register, renewal reminders and server-side clinical access denial.
Managers cannot explain access decisions	Approval evidence, recertification, risk explanations and searchable correlated audit history.

2. Baseline and final inventory

Area	Version 8 baseline	Version 9 change
Core lifecycle	Join / move / leave and independent requests	Service-layer authorization, date gate, last-operator safety and team consistency.
Care eligibility	Role, facility and assignments	Verified qualification checks, multi-stage cover and resident-specific emergency access.
Agency roster	CSV stage / approve / apply	No missing agency expiry, 24-hour approval limit, self/approver removal guard, actionable tasks.
Operational automation	Campaign scheduler and expiry preview	Daily transactional idempotent expiry job, reminders, session cleanup and policy settings.
Sessions / HTTP	CSRF and cookie-based local sessions	Session digests, rate limits, stricter script CSP, request IDs and query-redacted logging.
Governance visibility	Reviews, compliance, audit list	Explainable risk, safe question-based reporting, accurate campaign counts and audit search.
External infrastructure	Entra sign-in scaffolding; mock directory	Explicit connector contract and read-only SCIM-shaped representation; no fake live connections.

The original uploaded implementation also includes Flask / MS identity code and guarded Graph/PowerShell work. Those original files and historical evidence remain preserved. Their historical tenant results are not counted as newly executed version 9 tests.

Workforce and lifecycle

Capability	What the final release does	Change
Directory and roles	42 fictional workers; permanent, casual, agency and third-party records; seven selectable primary roles including SiteDelegate. Search, filters and profile views.	Existing + extended
Joiners	Validated names, IDs, email, role, site, sponsor and dates; dry run and creation. Agency end dates required. Future starters cannot sign in before their UTC start date.	Hardened
Role / site changes	Self-service request, independent decision, seven-day approval validity, current-state snapshot, one-use operator execution; clears old resident assignments and sessions.	Existing + hardened
Leavers	Disables mock identity, removes roles and assignments, deletes sessions and blocks sign-in; keeps evidence. Self-removal and last-operator loss are blocked.	Hardened
Bulk roster	Up to 100 rows / 32 KB per CSV. Immutable ID and email check; staged preview, independent approval and separate executor; stale or >24-hour approval rejected. Unknown workers become findings.	Hardened
Onboarding / handover	Four-step evidence checklist, append-only notes, categories and worker history; 35 sample notes. Checklist completion does not itself grant access.	Existing
Organisation / delegation	Sunhaven organisation, three sites and three teams. Team membership follows lifecycle changes. SiteDelegate can verify qualifications only within a time-limited delegated site.	New

Access control and care assurance

Capability	What the final release does	Change
RBAC / contextual access	Server-side roles plus worker status, start date, agency end date, site, resident assignment and current qualifications. These are measured local attributes; device/risk policy lab remains a simulator.	Extended
Qualifications	Safeguarding, professional registration, medication competency, moving and handling. Independent verification, expiry and evidence reference; 46 initial synthetic records.	New
Clinical restriction	Safeguarding required for care routes and resident view. Nurses additionally need current professional registration for clinical/resident access. Medication/handling tracked, not linked to nonexistent clinical tasks.	New
Access packages	Care learning, aggregate quality review and temporary incident response; independent approval, expiry, snapshot validity and package-level separation of duties.	Existing
Temporary site cover	Qualified nurse requests a site and bounded duration; Manager approves, different IAMOperator approves; automatically denied after expiry or changed worker state.	New
Emergency access	Qualified nurse deliberately activates access to one named fictional resident; reason and incident reference; default 15-minute limit; notification and independent review that also closes access.	New
Session security	Random bearer token in HttpOnly cookie; only SHA-256 digest in DB; 15-minute default absolute lifetime; revoke on mover/leaver; Secure cookie in production.	Hardened

Governance and intelligence

Capability	What the final release does	Change
Access reviews	Individual Retain / Change / Remove / Temporary Exception with evidence; no self-attestation; pending remediation must be completed and closed with evidence.	Hardened
Quarterly certification	Idempotent quarterly campaign and worker-state snapshot; independent attestation. Remove revokes access packages and creates a core-access remediation task. Full campaign pending count.	Hardened
Compliance	C01-C08 deterministic workforce checks; stored findings; policy and risk catalogue P01-P10 / R01-R07; credential/risk findings in dedicated assurance pages.	Existing + optimized
Risk explanations	Transparent 0-100 score: expired agency contract, missing qualifications, dormancy, unexpected admin privilege and repeated denied access. Human review recommended.	New
Plain-language reporting	Allowlisted questions for dormant accounts, qualification gaps, agency risks and high-risk workers. No LLM or arbitrary SQL; unsupported questions rejected.	New
Security analysis	Original SITAS engine and six-scenario comparisons; synthetic MFA-fatigue detection and explanations; invitation validation through preserved SAIF engine.	Existing / integrated
Incident and machine identities	Temporary-responder-controlled incident workflow; service/agent registry with owner, bounded scope and expiry. Registry does not execute agents or create live credentials.	Existing

Operations and platform

Capability	What the final release does	Change
Automation	Daily idempotent mock-directory agency disable, expired session cleanup, temporary-cover expiry, credential renewal reminders and overdue emergency-review alerts. Scheduled invocation is operator configured.	New
Notifications	Existing scoped live reminders plus durable recipient-specific notification outbox and read status. Email delivery is explicitly not configured.	Extended
Policy configuration	Bounded dormancy, reminder, emergency and cover durations; automatic agency expiry toggle; optimistic version check and audit reason.	New
Audit investigation	Sanitised actor / target / result / correlation metadata; full-history server search, 50-row pagination and expandable evidence. HMAC chain plus local checkpoint detects alteration.	Improved
Reports and exports	Filtered aggregate PDF, workforce/review/audit CSV with formula neutralisation; verified consistent NDJSON export with checksum and no overwrite.	Improved
Read-only API	Session-authenticated /api/v1 employees, qualifications, risks, health, docs and SCIM-shaped Users; scoped results, page-size validation and rate limit.	New
Integration boundary	Typed change/result protocol and unconfigured adapters for Entra, Okta, HRIS, payroll, rostering, Microsoft 365, SCIM, SIEM, email. Fail closed; no remote side effects claimed.	New
Usability	Consistent teal/navy theme, dark mode, responsive styles, skip link, keyboard focus, label associations, empty/error states and double-submit prevention. Browser QA remains outstanding.	Improved
Deployment / resilience	Python 3.12+, dependency-free demo, Waitress adapter, Docker configuration, health endpoint, environment checks, SQLite WAL, backups and restore rehearsal.	Existing + verified

3. Demonstrated workforce workflows

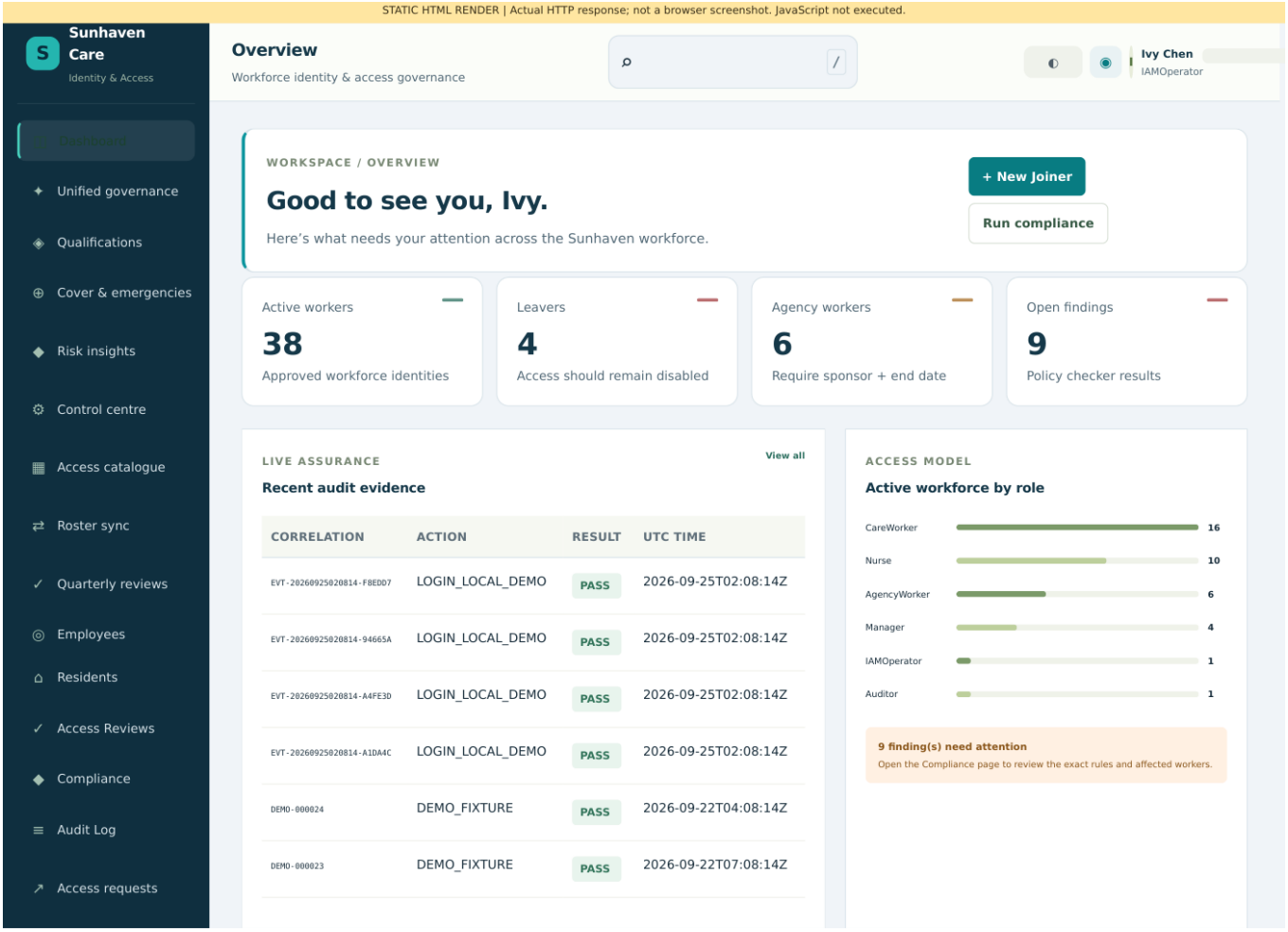


Figure 1. Dashboard HTML captured from the running server, rendered offline. The seeded open findings are deliberate demonstration conditions, not successful-control claims.

The dashboard combines workforce totals, recent audit events, agency deadlines and access-role distribution. Seed data includes an expired agency worker so the presentation can demonstrate detection followed by remediation. A clean database therefore intentionally begins with findings.

Qualified and temporary access

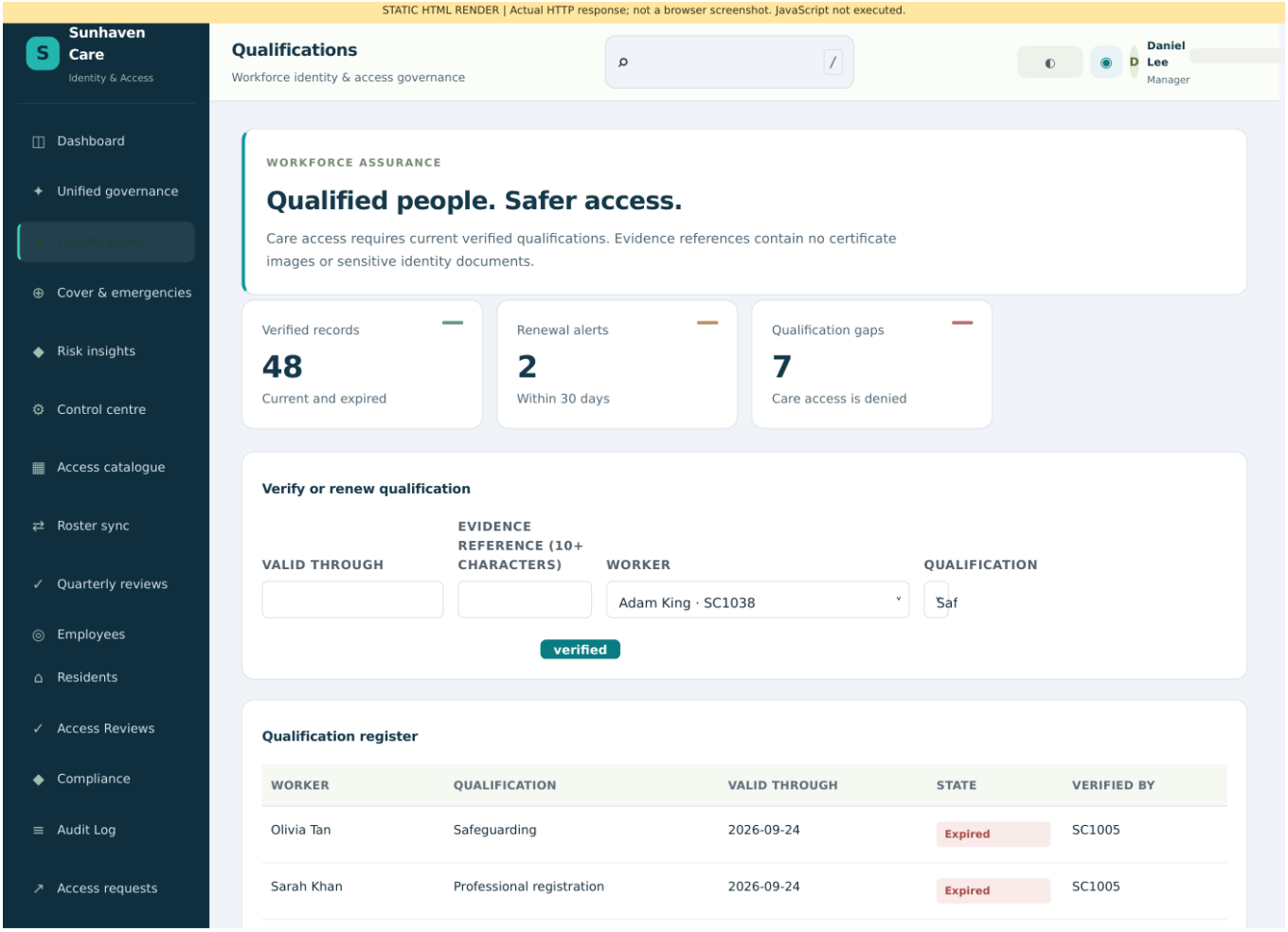


Figure 2. Qualification register during the acceptance run. An expired registration was deliberately introduced in the isolated test fixture; the clinical route returned HTTP 403 until independent renewal.

Managers or operators verify credential type, expiry and an evidence reference. A SiteDelegate may perform this action only within an unexpired delegated site. Workers cannot verify their own qualifications. The application stores references, not copies of identity documents.

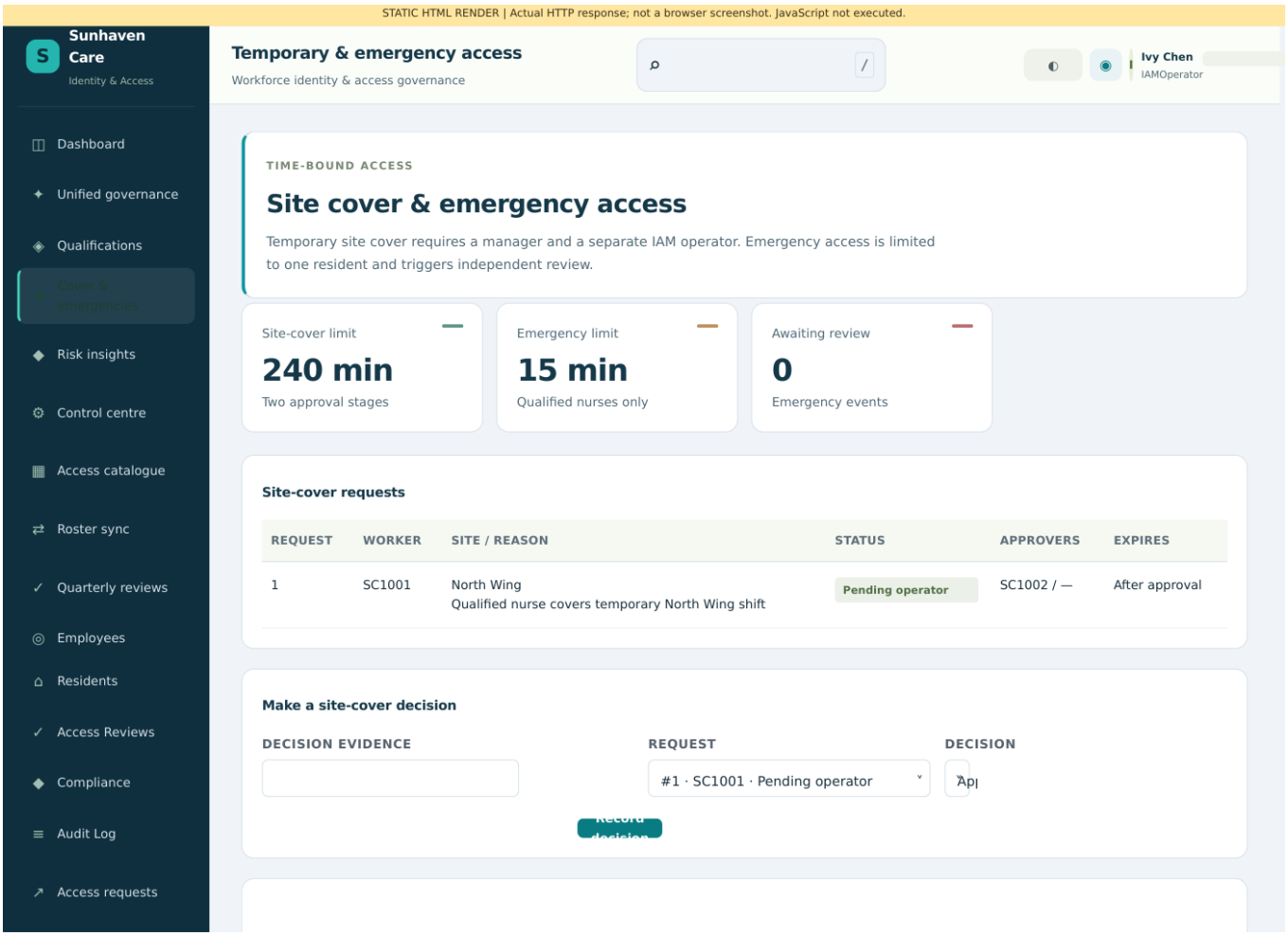


Figure 3. The nurse cover request after manager approval, awaiting a different IAM operator. The actual HTTP test confirmed resident scope only widened after the second approval.

Emergency care access and review

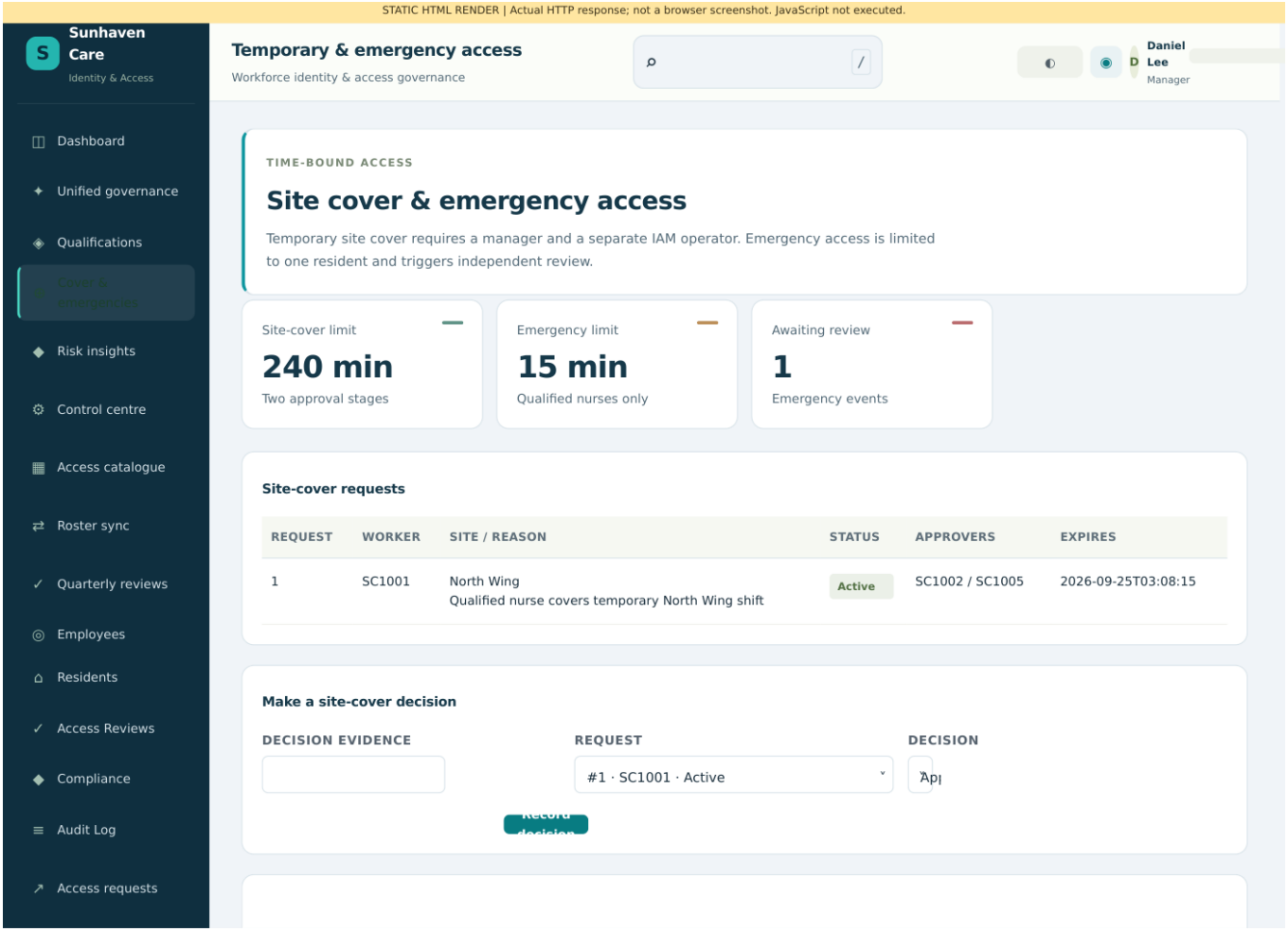


Figure 4. Emergency-access evidence captured for the manager. The full saved HTML also contains the resident, justification, incident reference and review control below this first-page rendering.

Emergency access is a deliberate human action, not an AI decision. A qualified nurse enters a resident ID, incident reference and reason. A policy-bounded grant opens only that resident record. It does not create an administrator role or bypass qualifications. An independent reviewer records evidence and closes the grant; time expiry is checked without waiting for a scheduled job.

Risk, certification and roster control

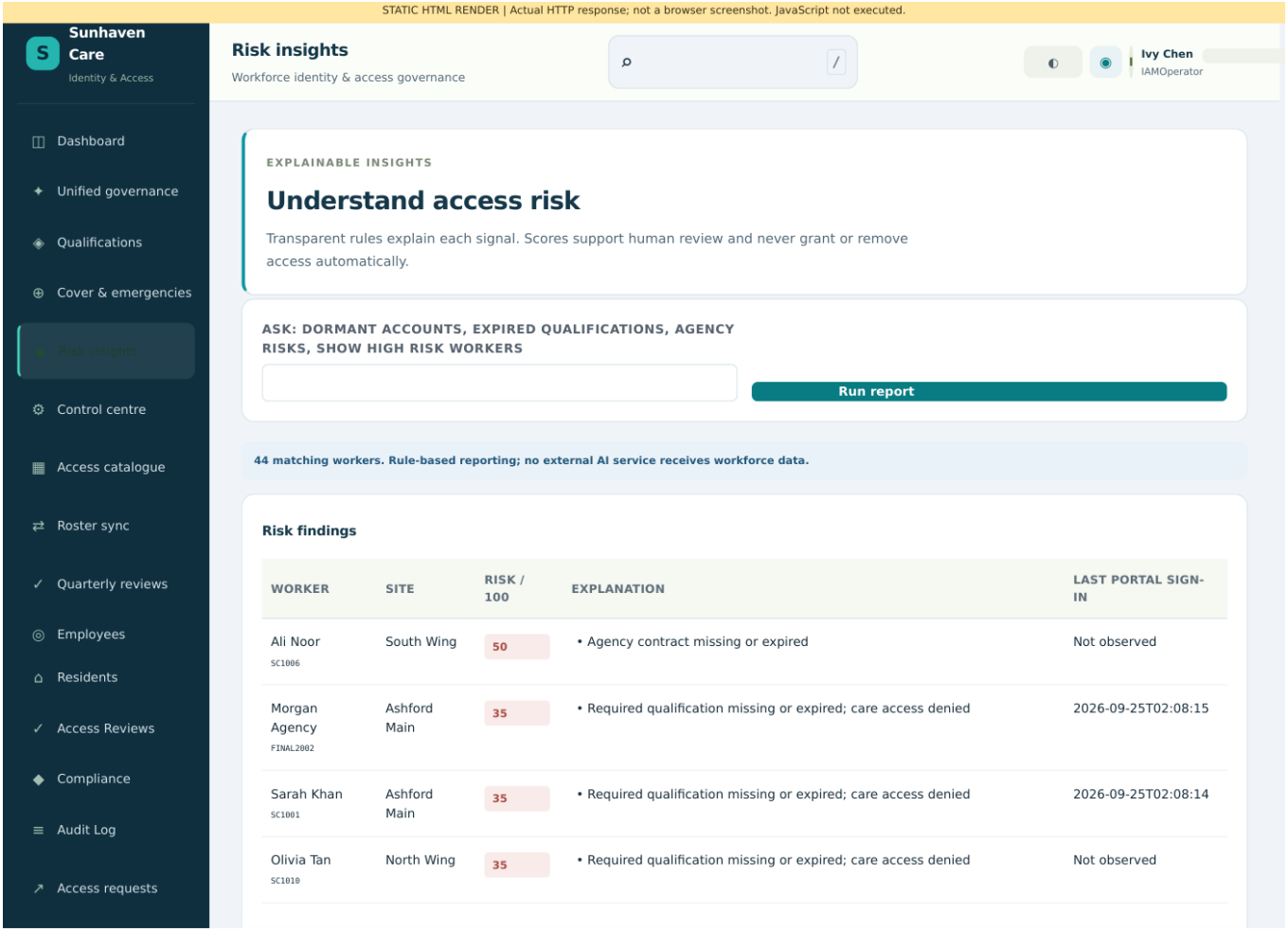


Figure 5. Explainable risk results from the isolated running fixture. Each score has explicit reasons; unknown sign-in history is described as not observed rather than proof that a person never worked.

Dormancy uses locally observed portal sign-ins, falling back to the workforce start date. It does not claim visibility into Microsoft 365, HRIS or a separate clinical application. Repeated denied portal accesses are a rule-based anomaly signal. Recommendations require a manager to investigate.

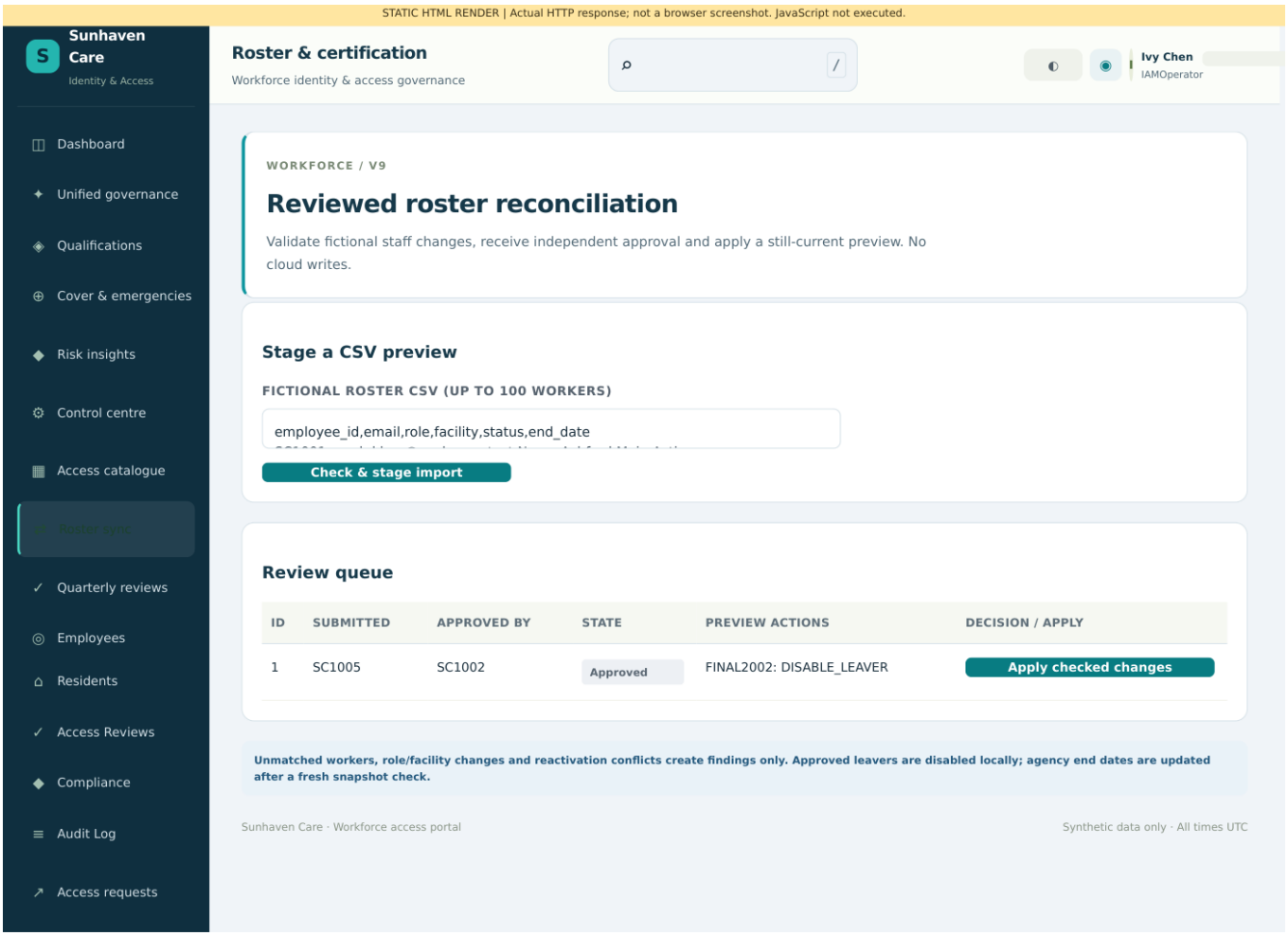


Figure 6. Reviewed agency-leaver import before execution. The acceptance run confirmed that the later approved apply removed the agency worker's mock access.

Audit and operations

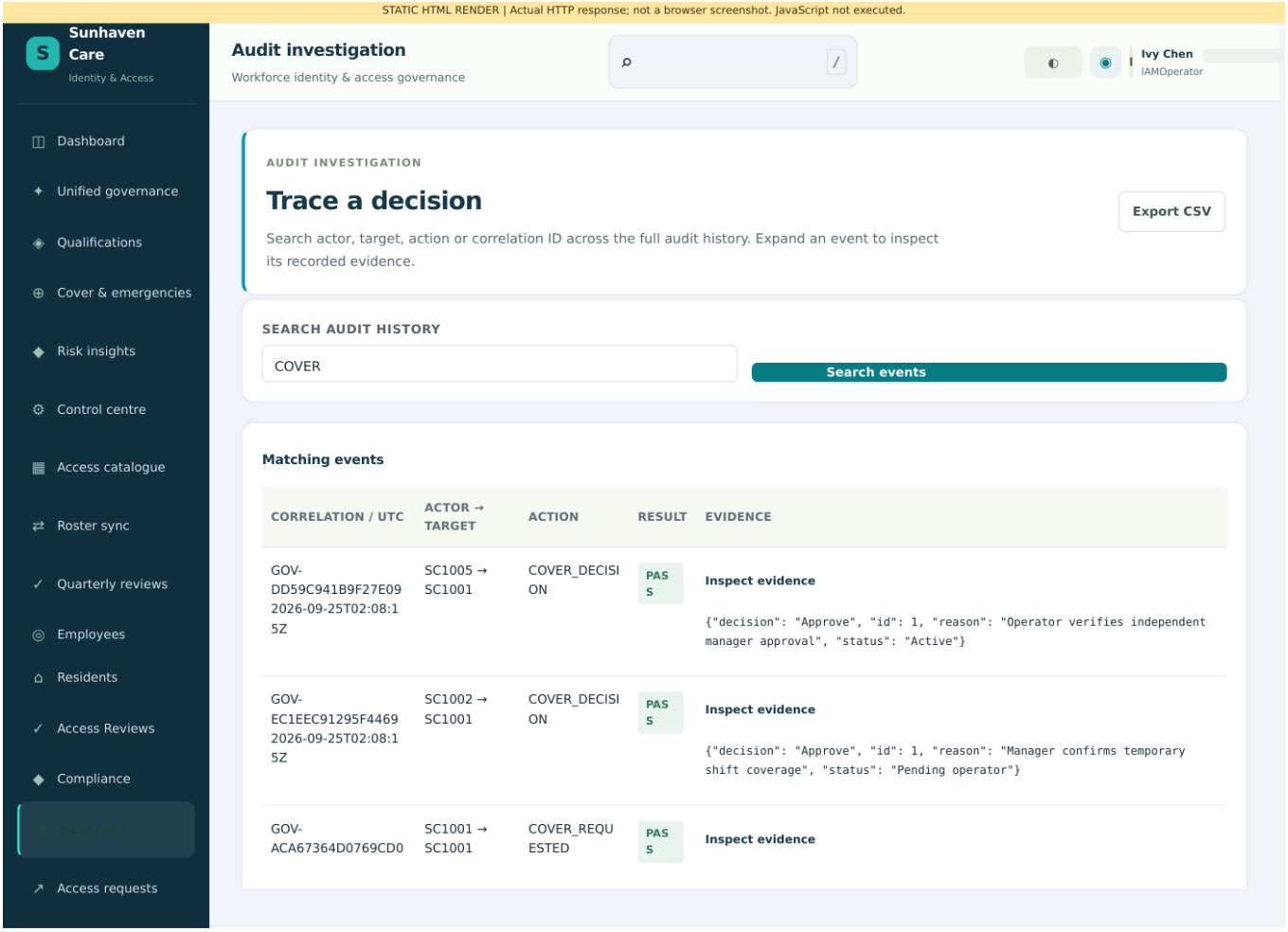


Figure 7. Full-history audit search for COVER events, with expandable recorded evidence. The acceptance test checked that COVER_DECISION events were returned.

The audit ledger is tamper-evident local evidence, not immutable remote storage. Its database, signing-key sidecar and signed checkpoint must be backed up together with writers stopped. An administrator controlling the host and key remains a threat. The verified export now reads and validates one consistent locked snapshot and refuses to overwrite an existing destination.

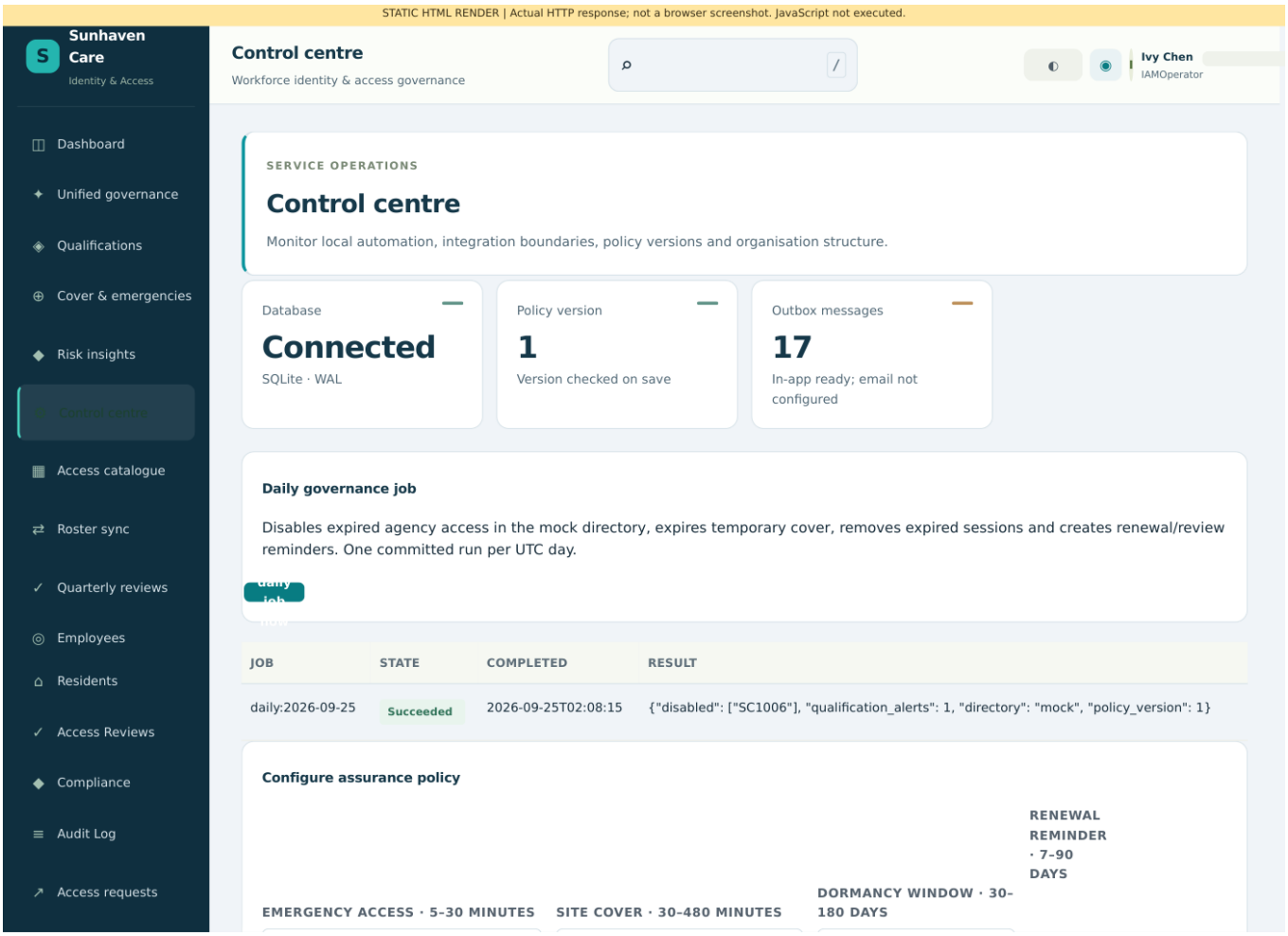


Figure 8. Control centre after the daily job was run twice. The database contained one completed daily-job row, demonstrating idempotence.

4. Security and automation changes

Control	Implementation and practical boundary
Authentication	Local identity chooser is password-free and intended for a loopback-only synthetic demo. Production configuration requires Entra mode, HTTPS redirect, secrets and seed disabled. Live tenant sign-in was not exercised.
Session handling	256-bit random bearer token; database stores SHA-256 digest; HttpOnly / SameSite cookies; Secure in production. Upgrade deliberately invalidates existing sessions.
Authorisation	Checks active/unblocked state, start date, current role, contract expiry, resource context and qualification. Direct URLs/API paths are checked server-side.
Request protection	Signed double-submit CSRF; 64 KB form-body limit; parameterised SQL; escaped HTML; independent decisions; bounded durations.
HTTP hardening	Scripts restricted to self; object embedding disabled; frame ancestors denied; nosniff; no-store; request ID. CSS retains inline styles for numeric charts.
Abuse controls	Persistent fixed-window limits: 30 login attempts/minute and 120 API calls/minute per direct client address. A reverse proxy needs its own trusted-client and edge-limit configuration.
Safety guards	Self termination, last active operator removal and self-attestation denied; missing agency expiry fails closed; roster approval expires after 24 hours.
Sensitive logging	Development request logs omit query strings, including OIDC authorization codes. Audit secret fields are redacted; users must not enter secrets in free-text evidence.

Automated and intelligent behavior

The daily job is atomic and once per UTC day. It disables expired or incomplete agency access in the mock directory under the configured policy, removes expired sessions, marks cover grants expired, and writes qualification and overdue emergency-review notifications. Run it through the control centre or an operating-system scheduler; the application does not install a background service automatically.

Intelligent functions are intentionally explainable rules: risk scoring, MFA pattern detection, suggested investigation and allowlisted natural-language report selection. There is no external LLM, autonomous high-risk approval, model training, or claim of predictive accuracy. Live policy recommendation generation and general conversational reporting are not implemented.

5. Architecture and data design

Layer	Main implementation
Presentation	Server-rendered HTML through reusable ui.py and page mixins; shared CSS and small JavaScript enhancements.
Transport	Dependency-free ThreadingHTTPServer for local use; the same handlers run behind the WSGI adapter and Waitress for deployment testing.
Business services	lifecycle.py, governance.py, enterprise.py, workforce_v8.py and new assurance.py implement validation, decisions and state changes.
Persistence	SQLite WAL and foreign keys; additive version-9 migration; 15-second busy timeout; transaction context now closes connections reliably.
Security evidence	audit.py plus security_workstream/ledger.py; atomic governance events and local signed checkpoints.
Integration	Read-only original-module subprocess adapters with fixed arguments/timeouts; connectors.py protocol; mock directory only.
Verification	unittest, original pytest suites, isolated real-HTTP acceptance harness, preflight, backup rehearsal, AST scan and original-file hash check.

New tables and changed semantics

Tables	Purpose
schema_versions; assurance_policy	Additive migration record and validated, versioned policy settings.
qualifications; login_activity	Independent credential verification / expiry and locally observed last sign-in.
sites; teams; team_members; admin_delegations	Organisation relationships and time-limited scoped administration.
cover_requests; cover_decisions; emergency_grants	Two-stage site coverage, decision evidence, narrow emergency grant and review.
operational_jobs; notification_outbox; http_rate_limits	Idempotent job evidence, recipient-specific durable messages and bounded request counts.
Existing sessions table	Token column now holds a digest. Existing sessions are revoked when migration 9 first runs.
Existing workforce/audit tables	Preserved; additional indexes, consistent UTC date evaluation, stricter service checks and consistent export snapshot.

Fresh seed initialization produced 40 application tables. No claim of multi-region, multi-tenant isolation or high-availability database support is made. SiteDelegate scope is enforced for the new qualification/insight/API surfaces; Manager, Auditor and IAMOperator remain organisation-wide governance roles.

Performance and maintainability

Batched compliance/risk queries and paginated audit search reduce work. SQLite remains a single-host limitation.

6. Verification results and second audit

Verification	Result	Evidence
Portal unit / WSGI integration	88 passed	evidence/all-tests-v9.txt
Original SITAS	66 passed	evidence/all-tests-v9.txt
Original SAIF	13 passed	evidence/all-tests-v9.txt
HTTP acceptance / local server	15 scenario groups; 103 requests passed	evidence/http-acceptance-v9.json
HTTP acceptance / Waitress	Same 15 groups; 103 requests passed	evidence/http-acceptance-waitress-v9.json
Fresh start / schema / FKs	PASS; integrity ok; 0 FK errors	evidence/preflight-v9.json
Backup / restore rehearsal	PASS, including signed ledger	evidence/backup-restore-v9.json
Original-source preservation	545 files, 0 mismatches	evidence/verify-original-v9.json
Static security pattern scan	50 Python modules parsed; no scanned dangerous calls found	evidence/static-audit-v9.json
Browser / mobile / keyboard E2E	Not completed: localhost blocked in remote browser	Documented limitation
Live cloud / Docker build / load test	Not executed in this environment	Requires deployment environment

Observed localhost request latency in the small synthetic fixture: stdlib median 4.74 ms, p95 7.49 ms; Waitress median 4.45 ms, p95 7.01 ms. These are sequential acceptance-run observations, not a load benchmark or service-level guarantee.

Acceptance scenarios

Scenario	Result
36 principal pages, APIs and assets respond successfully	PASS
Permanent and agency onboarding persist validated workforce records	PASS
Approved role change and site transfer revoke stale sessions and update access	PASS
Rejected access request never changes the worker role	PASS
Two-stage temporary site cover changes permitted resident scope	PASS
Emergency grant is resident-specific; independent review closes access	PASS
Expired qualification denies clinical access; independently verified renewal restores it	PASS
Policy violation scan produces persisted actionable findings	PASS
Quarterly campaign captures and persists an independent attestation	PASS
Termination removes roles, assignments and sessions and blocks login	PASS
Reviewed roster offboarding deprovisions an agency worker	PASS
Daily job disables expired agency account once; repeated run is idempotent	PASS
Direct URL/API authorisation and pagination validation reject invalid requests	PASS
Audit investigation returns correlated decision details and integrity screen	PASS
Database integrity and all foreign-key checks pass after full lifecycle run	PASS

Expected HTTP 400/401/403/429 responses are security or validation outcomes, not defects. The expiry test deliberately changes the isolated fixture date; the production UI does not permit an expired qualification to be newly verified. No acceptance tests modify the user's existing database.

Second-audit findings and fixes

Finding	Resolution
UTC/local date mismatch	One UTC business-day helper now drives all portal contract and qualification dates; regression added.
Potential missing agency end-date bypass	Central employment eligibility gate rejects incomplete/expired agency records in sessions and service-layer checks.
Evidence export concurrency / overwrite	One locked, verified audit snapshot; atomic no-overwrite destination creation.
Campaign pending count based on subset	Full campaign pending totals calculated in SQL; latest-100 item list is explicitly labelled.
Cover and emergency approvals lacked enough visible context	Business reason, incident reference and resident context included in decision evidence views.
Lifecycle team metadata could become stale	Joiner and mover workflows synchronize site-team membership transactionally.
Approval and administrator safety gaps	24-hour roster expiry; no self/last-operator removal; approver cannot be removed by that roster import.
Session secrets persisted directly	Digest storage and migration-time session revocation.
Potential sign-in code exposure in local server log	Log method/path/status/request ID only; strip query strings.
Version and runtime instructions were outdated	Release docs and preflight specify Python 3.12+; current docs take precedence over historical material.

7. Run and demonstrate

1. Extract the entire ZIP. Open the sunhaven_final_v9 folder. Install Python 3.12 or newer.

2. Run python qa/preflight.py. Expect PASS. On Windows use py -3.12 instead of python if needed.

3. Run python run.py, or double-click start_windows.bat. Keep the terminal open.

4. Open http://127.0.0.1:8000. Select Ivy Chen - IAMOperator. The first start creates the synthetic database.

5. Follow the separate operator handbook for scenario inputs, role changes and recovery. Use a fresh demo copy for the presentation.

Presentation segment	Suggested demonstration
1 minute	Explain high turnover and why access must follow employment, role, site and qualification.
2 minutes	Show dashboard, worker directory, notes and seeded compliance findings.
3 minutes	Join a fictional worker; submit a change as the worker; approve as Daniel; execute as Ivy.
3 minutes	Show Sarah's qualification and request site cover; manager stage, operator stage, resident scope.
2 minutes	Activate a named-resident emergency grant as Sarah; review and close it as Daniel.
2 minutes	Run quarterly review and daily expiry job; show agency access disabled and notifications.
2 minutes	Search audit decisions; show integrity status, report/export and honestly explain external-integration boundary.

8. Deployment gates and future customisation

Required before real production	What must be supplied or verified
Identity provider	Entra tenant/app registration, secret managed outside source, HTTPS redirect, immutable object IDs, approved MFA / Conditional Access policy and successful tenant tests.
Provisioning	Implement and test a real adapter with least-privilege service identity, idempotency, reconciliation, retry/dead-letter handling and partial-failure recovery. Portal real Graph mode remains disabled.
Hosting	TLS reverse proxy, private networking, encrypted persistent storage, monitored single-process deployment, backups, restore drills, patching and agreed service ownership.
Operations	OS scheduler, real email transport and SIEM destination, alert routing, retention/deletion policy and independently protected signing keys.
Care policy	Confirm role/qualification matrix, emergency justification and review time, real facility/team hierarchy, agency approval responsibilities and timezone requirements.
Quality and assurance	Browser/mobile/keyboard/screen-reader testing, independent penetration test, dependency review, accessibility audit, concurrent-load tests and recovery objectives.
Scale	Move to a managed multi-user database and distributed job/ledger architecture before claiming enterprise-scale or multi-node availability.

The typed connector interfaces are extension points, not working Entra/Okta/HRIS/email integrations. SCIM output is a read-only representation, not a certified SCIM provisioning server. A durable notification outbox exists, but there is no email delivery retry worker. The daily local job rolls back on failure and can be retried; it is not a distributed queue.

Further customisation includes enterprise-wide delegated scopes, automatic bulk onboarding from an authoritative HRIS, custom role-template administration, policy authoring beyond the bounded settings, real device/risk telemetry, privileged session recording, general conversational reporting, localization and disaster-recovery automation. These are explicitly outside the tested release. Future product features cannot be guaranteed or exhaustively implemented in advance.

9. References and evidence

Conceptual comparison used current primary documentation. The product applies selected principles; this is not an OWASP certification, regulatory compliance assessment or claim of equivalence to a commercial IGA platform.

OWASP. Application Security Verification Standard (ASVS). Accessed 25 September 2026. https://owasp.org/www-project-application-security-verification-standard/

Microsoft Learn. Microsoft Entra ID Governance overview. Accessed 25 September 2026. https://learn.microsoft.com/en-us/entra/id-governance/identity-governance-overview

Microsoft Learn. What are lifecycle workflows? Accessed 25 September 2026. https://learn.microsoft.com/en-us/entra/id-governance/what-are-lifecycle-workflows

Microsoft Learn. What are access reviews? Accessed 25 September 2026. https://learn.microsoft.com/en-us/entra/id-governance/access-reviews-overview

Source preservation: ORIGINAL_MANIFEST.json and original/. Runtime evidence: evidence/all-tests-v9.txt, HTTP JSON logs, preflight, static audit and backup rehearsal. The 12 captured HTML pages and their labelled offline renderings are under evidence/rendered-pages and evidence/page-renders. Historical docs and evidence are retained; this report and the v9 handbook are authoritative for the final release.